Task 4: Least-Privilege Access Controls

System: Northstar Assist. **Date:** 2026-10-10. **Roles reviewed:** harness execution role, gateway service role, knowledge base service role.

1. Summary

The roles the console created for Northstar Assist were broader than the system needs. After hardening:

- The **harness role** can invoke only Claude Haiku 4.5, only through the US inference profile, and **only when the Northstar guardrail (or the IR lockdown guardrail) is attached to the request**. It can apply only those two guardrails, call only the Northstar gateway, and write only to its own log group. Browser, Code Interpreter, Memory, file-system and Bedrock Mantle permissions are gone.
- The **gateway role** can read and retrieve from only the Northstar knowledge base. Agentic retrieval, reranking, model invocation and "any guardrail" permissions are gone.
- The **knowledge base role** can invoke only Titan Text Embeddings V2 and read only the document bucket. Marketplace subscription permissions are gone.

Measure	Before	After
Statements in the harness execution policy	21	13 (12 Allow, 1 Deny)
Simulated checks allowed (35-row matrix, section 5)	22	10
Simulated checks denied	13	25
Harness still answers with retrieval	Yes	Yes
Guardrail can be skipped with a per-request model override	**Yes**	**No (AccessDenied)**
Harness can be switched to another model per request	**Yes**	**No (AccessDenied)**

2. Roles and how the change was applied

Role	Name	Policies changed
Harness execution role	`AmazonBedrockAgentCoreHarnessDefaultServiceRole-37uao`	`AmazonBedrockAgentCoreHarnessExecutionPolicy_mvv5o` replaced. `AmazonBedrockAgentCoreHarnessGateway`

Role	Name	Policies changed
		`Policy_jg379` unchanged (already scoped to the one gateway). Inline `NorthstarAssistApplyGuardrail` added in Task 5.
Gateway service role	`AmazonBedrockAgentCoreGatewayDefaultServiceRole1791659264711`	… `GatewayKBAccessProd_705231` and … `GatewayBasePolicyProd_05C6A3` replaced
Knowledge base service role	`AmazonBedrockExecutionRoleForKnowledgeBase_x7ne0`	… `FoundationModelPolicyForKnowledgeBase_x7ne0` replaced. S3 and CloudWatch policies unchanged (already scoped).

- **Original documents:** `iam/before/<role>/` (snapshotted before any change).
- **Scoped documents:** `iam/after/*.json`. IAM Access Analyzer `validate-policy` reports no findings on any of them.
- **Applied by:** `infra/04_iam_harden.sh`, which publishes each scoped document as a new default version of the existing customer-managed policy and re-snapshots the roles into `evidence/task4/roles_after/`.
- **Rollback:** `infra/04_iam_harden.sh --rollback` re-applies the original documents as a new version. This was exercised once during the work (all seven live policies matched the originals afterwards) and the hardening was then re-applied.

3. Harness execution role: original permissions, changes and rationale

#	Original statement (console default)	Change	Rationale	What an attacker could do with the original
1	`bedrock:InvokeModel*` on `foundation-model/*` in every Region and on **every Bedrock resource in the account**	**Scoped** to the Haiku 4.5 US inference profile, and to the Haiku 4.5 foundation model in us-east-1, us-east-2 and us-west-2 only	The harness uses one model. The three Regions are the profile's routing destinations (`evidence/task4/infe`	Run any model in the account under the harness's identity: larger and costlier models, or models with no guardrail

#	Original statement (console default)	Change	Rationale	What an attacker could do with the original
		when called through that profile (`bedrock:InferenceProfileArn` condition)	`rence_profile.json`).	attached.
2	(none)	**Added a Deny**: model invocation is denied unless `bedrock:GuardrailIdentifier` equals the Northstar guardrail version 2 or the lockdown guardrail version 2	`InvokeHarness` accepts a per-request model configuration. Testing showed that a configuration without `guardrailConfig` skipped the guardrail (section 6). The Deny makes the guardrail mandatory at the IAM layer.	Send a request that drops the guardrail and talk to the model and the knowledge base tool unfiltered.
3	`bedrock-mantle:CreateInference` on the account, `bedrock-mantle:CallWithBearerToken` on *	**Removed**	The harness uses the Bedrock Converse API, not Bedrock Mantle.	Reach models through a second API path that the guardrail condition does not cover.
4	Browser tool: start, stop, get, list sessions and connect streams on	**Removed**	The Browser tool is not configured.	Drive a managed browser from the agent's identity: fetch attacker-

#	Original statement (console default)	Change	Rationale	What an attacker could do with the original
	`browser/*`			controlled pages, exfiltrate data to the internet.
5	Code Interpreter: start, stop, get, list sessions and invoke on `code-interpreter/*`	**Removed**	The Code Interpreter tool is not configured.	Execute arbitrary code in a managed sandbox under the agent's identity.
6	EFS: `ClientMount`, `ClientWrite`, describe on every file system and access point in the account	**Removed**	No file-system mounts are configured.	Read and write any EFS file system in the account that has an access point.
7	S3 Files: `ClientMount`, `ClientWrite`, `ClientRootAccess`, describe on every file system in the account	**Removed**	No file-system mounts are configured.	Mount S3-backed file systems with root access.
8	Memory: create, delete, get, list events and retrieve records on `memory/NorthstarAssi`	**Removed**	Memory is disabled on the harness.	Read or plant long-term memory records if memory were enabled later.

#	Original statement (console default)	Change	Rationale	What an attacker could do with the original
	`st-*`			
9	CloudWatch Logs: create group, describe streams, create stream, put events on **every** runtime's log group (`runtimes/*`)	**Scoped** to this harness's runtime log group (`runtimes/harness_NorthstarAssist-92Prr07JAK-*`)	The runtime writes only its own logs.	Write misleading entries into other agents' runtime logs.
10	`logs:PutResourcePolicy` on the harness log group	**Removed**	Not needed after creation; a resource policy on a log group is a privilege-granting action.	Grant other principals access to the log group.
11	`bedrock-agentcore:GetWorkloadAccessToken*` on the default workload identity directory and `harness_NorthstarAssist-*`	**Kept**	Required for the harness to obtain its workload identity. Already limited to this harness's name prefix.	—
12	ECR: public and private authorization tokens, STS service bearer token, image pull on `repository/harness-*`	**Kept** (see section 4)	The runtime pulls the AWS-managed harness container image.	—

#	Original statement (console default)	Change	Rationale	What an attacker could do with the original
13	X-Ray: put trace segments and telemetry, get sampling rules and targets on *	**Kept** (see section 4)	Runtime tracing.	—
14	`cloudwatch:PutMetricData` on * with the namespace fixed to `bedrock-agentcore`	**Kept** (see section 4)	Runtime metrics.	—
15	`bedrock-agentcore:InvokeGateway` on the Northstar gateway ARN (separate policy)	**Kept**	Already scoped to exactly one gateway.	—
16	(added in Task 5) `bedrock:ApplyGuardrail` on the two guardrail ARNs (inline policy)	**Kept**	The console role has no `ApplyGuardrail` permission; the inline policy grants it for exactly the two guardrails.	—

4. Wildcards that remain, and why

The rubric allows a wildcard only where it is justified. Six remain in the harness policy. None of them grants access to data.

Statement	Wildcard	Justification
`ecr-public:GetAuthoriz`	`Resource: "*"`	These actions do not support resource-level

Statement	Wildcard	Justification
`ationToken`, `sts:GetServiceBearerToken`, `ecr:GetAuthorizationToken`		permissions; AWS requires *. They return a registry login token and grant no access to any repository by themselves.
`ecr:BatchGetImage`, `ecr:GetDownloadUrlForLayer`, `ecr:BatchCheckLayerAvailability`	Account wildcard in `arn:aws:ecr:us-east-1:*:repository/harness-*`	The harness image lives in an AWS-owned account whose ID is not published. The repository name is restricted to `harness-*` and the Region to us-east-1.
`xray:PutTraceSegments`, `xray:PutTelemetryRecords`, `xray:GetSamplingRules`, `xray:GetSamplingTargets`	`Resource: "*"`	X-Ray write and sampling actions do not support resource-level permissions.
`cloudwatch:PutMetricData`	`Resource: "*"`	The action does not support resource-level permissions. A condition restricts it to the `bedrock-agentcore` namespace.
`logs:DescribeLogGroups`	`log-group:*`	A list action evaluated against the account's log groups; it returns names and metadata only, no log content.
Deny statement (guardrail enforcement)	`Resource: "*"`	A Deny on * narrows access. It applies the guardrail requirement to every model the role could ever be granted.

No wildcard **action** remains in any of the three roles.

5. Gateway and knowledge base roles

Gateway service role

Original statement	Change	Rationale	What an attacker could do with the original
`bedrock:GetKnowledgeBase`, `bedrock:Retrieve` on the Northstar knowledge base ARN	**Kept**	Exactly what standard retrieval needs.	—
`bedrock:AgenticRetrieveStream` on *	**Removed**	The target uses Standard retrieval, not Agentic retrieval.	Run agentic retrieval against any knowledge base the action reaches.
`bedrock:InvokeModel*` on every foundation model, inference profile, provisioned model and custom model (when called via Bedrock)	**Removed**	The gateway does not generate text. The harness does.	Use the gateway's identity to drive model invocations through Bedrock features.
`bedrock:Rerank` on * (when called via Bedrock)	**Removed**	No reranking is configured.	—
`bedrock:GetInferenceProfile` on every inference profile (when called via Bedrock)	**Removed**	Not needed without model invocation.	Enumerate inference profiles.
`bedrock:ApplyGuardrail` on **every guardrail** (when called via Bedrock)	**Removed**	Guardrails are applied by the harness, not the gateway.	Probe any guardrail in the account to learn what it blocks.
`bedrock-agentcore:Get`	**Scoped** to the exact gateway	Removes the name-prefix	Read the configuration of

Original statement	Change	Rationale	What an attacker could do with the original
`Gateway` on `gateway/northstar-assist-gateway-*`	ARN	wildcard.	any future gateway whose name starts the same way.
`bedrock-agentcore:GetConfigurationBundleVersion` on every configuration bundle	**Removed**	No configuration bundles are used.	Read other gateways' configuration bundles.

After the change the harness still retrieved 5 chunks for the test prompt, which shows the gateway needs nothing beyond `GetKnowledgeBase` and `Retrieve` on the one knowledge base.

Knowledge base service role

Original statement	Change	Rationale
`bedrock:InvokeModel` on `amazon.titan-embed-text-v2:0`	**Kept**	The embedding model.
`aws-marketplace:Subscribe`, `ViewSubscriptions`, `Unsubscribe` on * (when called via Bedrock)	**Removed**	Titan is a first-party model and needs no Marketplace subscription. In this lab the organization policy already denies the action; in a normal account the statement would let the role subscribe the account to third-party models.
`s3:ListBucket` on the document bucket; `s3:GetObject` on its objects, same account only	**Kept**	Read-only and limited to the one bucket. The role cannot write to the bucket.
`cloudwatch:PutMetricData` with the namespace fixed to `AWS/Bedrock/KnowledgeBases`	**Kept**	Service metrics.

After the change a sync job completed with 30 documents scanned and 0 failed (`evidence/task4/kb_sync_after_hardening.json`).

6. Proof

6.1 IAM policy simulator, before and after

`infra/04_iam_harden.sh --simulate` runs `iam simulate-principal-policy` on the three live roles for the 35 checks in `iam/simulation_matrix.json`. The "Before" column was taken with the original console documents in place, the "After" column with the scoped documents. Twelve checks changed from allowed to denied; none changed the other way.

Role	Action	Resource	What the check represents	Before	After
HARNESS	`bedrock:InvokeModelWithResponseStream`	`bedrock:us-east-1:<acct>:inference-profile/us.anthropic.claude-haiku-4-5-20251001-v1:0`	The approved inference profile, with the Northstar guardrail attached	allowed	allowed
HARNESS	`bedrock:InvokeModelWithResponseStream`	`bedrock:us-east-1:<acct>:inference-profile/us.anthropic.claude-haiku-4-5-20251001-v1:0`	The approved profile called WITHOUT the Northstar guardrail (per-request override)	allowed	**denied**
HARNESS	`bedrock:InvokeModelWithResponseStream`	`bedrock:us-east-1:<acct>:inference-profile/us.anthropic.cla`	The approved profile called with some other guardrail	allowed	**denied**

Role	Action	Resource	What the check represents	Before	After
		`ude-haiku-4-5-20251001-v1:0`			
HARNESS	`bedrock:InvokeModelWithResponseStream`	`bedrock:us-east-2::foundation-model/anthropic.claude-haiku-4-5-20251001-v1:0`	Haiku 4.5 in a destination Region, called through the profile, with the Northstar guardrail attached	allowed	allowed
HARNESS	`bedrock:InvokeModelWithResponseStream`	`bedrock:us-east-1::foundation-model/anthropic.claude-haiku-4-5-20251001-v1:0`	Haiku 4.5 called directly, not through the profile	allowed	**denied**
HARNESS	`bedrock:InvokeModelWithResponseStream`	`bedrock:us-east-1:<acct>:inference-profile/us.amazon.nova-2-lite-v1:0`	A different model's inference profile	allowed	**denied**
HARNESS	`bedrock:InvokeModel`	`bedrock:us-east-1::foundati`	A different foundation model	allowed	**denied**

Role	Action	Resource	What the check represents	Before	After
		on-model/amazon.nova-2-lite-v1:0			
HARNESS	bedrock:InvokeModel	bedrock:us-east-1::foundation-model/anthropic.claude-sonnet-4-5-20250929-v1:0	A larger, costlier model	allowed	**denied**
HARNESS	bedrock:ApplyGuardrail	bedrock:us-east-1:<acct>:guardrail/753a9dgwqe2f	The Northstar guardrail	allowed	allowed
HARNESS	bedrock:ApplyGuardrail	bedrock:us-east-1:<acct>:guardrail/1oom74pzn70o	The IR lockdown guardrail	allowed	allowed
HARNESS	bedrock:ApplyGuardrail	bedrock:us-east-1:<acct>:guardrail/aaaaaaaaaaaa	Any other guardrail	denied	denied
HARNESS	bedrock-agentcore:InvokeGateway	bedrock-agentcore:us-east-1:<acct>:ga	The Northstar gateway	allowed	allowed

Role	Action	Resource	What the check represents	Before	After
		`teway/northstar-assist-gateway-hd1uvsa8f3`			
HARNESS	`bedrock-agentcore:InvokeGateway`	`bedrock-agentcore:us-east-1:<acct>:gateway/other-gateway-abc123`	Any other gateway	denied	denied
HARNESS	`bedrock:Retrieve`	`bedrock:us-east-1:<acct>:knowledge-base/WUWHZC06MP`	Direct KB retrieval, bypassing the gateway	denied	denied
HARNESS	`bedrock-agentcore:StartBrowserSession`	`bedrock-agentcore:us-east-1:aws:browser/aws.browser.v1`	Browser tool (not configured)	allowed	**denied**
HARNESS	`bedrock-agentcore:InvokeCodeInterpreter`	`bedrock-agentcore:us-east-1:aws:code-interpreter/aws.codeinterpreter.v1`	Code Interpreter (not configured)	allowed	**denied**
HARNESS	`bedrock-agentcore:Retrie`	`bedrock-agentcore:us-`	Memory (disabled)	allowed	**denied**

Role	Action	Resource	What the check represents	Before	After
	veMemoryRecords	east-1:<acct>:memory/NorthstarAssist-abc			
HARNESS	elasticfilesystem:ClientWrite	elasticfilesystem:us-east-1:<acct>:file-system/fs-12345678	EFS mounts (not configured)	denied	denied
HARNESS	bedrock-mantle:CreateInference	bedrock-mantle:us-east-1:<acct>:project/default	Bedrock Mantle API (not used)	allowed	**denied**
HARNESS	s3:GetObject	s3:::northstar-assist-kb-5ca661ad/csv/employee_directory.csv	Direct read of the source documents	denied	denied
HARNESS	logs:CreateLogGroup	logs:us-east-1:<acct>:log-group:/aws/bedrock-agentcore/runtimes/harness_NorthstarAssist-	Its own runtime log group	allowed	allowed

Role	Action	Resource	What the check represents	Before	After
		`92Prr07JAK-DEFAULT`			
HARNESS	`logs:CreateLogGroup`	`logs:us-east-1:<acct>:log-group:/aws/bedrock-agentcore/runtimes/other-runtime-DEFAULT`	Another runtime's log group	allowed	**denied**
GATEWAY	`bedrock:Retrieve`	`bedrock:us-east-1:<acct>:knowledge-base/WUWHZC06MP`	The Northstar knowledge base	allowed	allowed
GATEWAY	`bedrock:GetKnowledgeBase`	`bedrock:us-east-1:<acct>:knowledge-base/WUWHZC06MP`	The Northstar knowledge base	allowed	allowed
GATEWAY	`bedrock:Retrieve`	`bedrock:us-east-1:<acct>:knowledge-base/OTHERKB123`	Any other knowledge base	denied	denied
GATEWAY	`bedrock:AgenticRetrieveStream`	*	Agentic retrieval (not configured; the action	allowed	**denied**

Role	Action	Resource	What the check represents	Before	After
			has no resource-level permissions)		
GATEWAY	`bedrock:InvokeModel`	`bedrock:us-east-1::foundation-model/anthropic.claude-haiku-4-5-20251001-v1:0`	Model invocation by the gateway	denied	denied
GATEWAY	`bedrock:Rerank`	*	Reranking (not configured)	denied	denied
GATEWAY	`bedrock:ApplyGuardrail`	`bedrock:us-east-1:<acct>:guardrail/753a9dgwqe2f`	Guardrails are applied by the harness, not the gateway	denied	denied
GATEWAY	`s3:GetObject`	`s3:::northstar-assist-kb-5ca661ad/csv/employee_directory.csv`	Direct read of the source documents	denied	denied
KB	`bedrock:InvokeModel`	`bedrock:us-east-1::foundation-model/`	The embedding model	allowed	allowed

Role	Action	Resource	What the check represents	Before	After
		`amazon.titan-embed-text-v2:0`			
KB	`bedrock:InvokeModel`	`bedrock:us-east-1::foundation-model/anthropic.claude-haiku-4-5-20251001-v1:0`	A generation model	denied	denied
KB	`s3:GetObject`	`s3:::northstar-assist-kb-5ca661ad/html/company_policies_handbook.html`	Reading the document bucket	allowed	allowed
KB	`s3:PutObject`	`s3:::northstar-assist-kb-5ca661ad/html/company_policies_handbook.html`	Writing to the document bucket	denied	denied
KB	`aws-marketplace:Subscribe`	*	Marketplace subscriptions (not needed for Titan)	denied	denied

Row files: `evidence/task4/simulation_before.jsonl`, `simulation_after.jsonl`.

6.2 Live tests through the harness

`tools/override_probe.py` sends real requests with per-request overrides (`evidence/task4/override_probe_before_hardening.json`, `… after_hardening.json`).

Probe	Request	Before hardening	After hardening
O-0	Injection prompt, no override (control)	Blocked by the guardrail	Blocked by the guardrail
O-1	Same model, model override that omits `guardrailConfig`, injection prompt	**Answered: the guardrail was skipped**	**AccessDeniedException**
O-2	System prompt override only, off-scope request	Blocked by the guardrail	Blocked by the guardrail
O-3	Model override without `guardrailConfig` plus a "no restrictions" system prompt, off-scope request	**Answered: guardrail and system prompt both bypassed**	**AccessDeniedException**
O-4	Switch the model to Amazon Nova 2 Lite, benign question	**Answered from the knowledge base (5 chunks), no guardrail**	**AccessDeniedException**

6.3 Nothing legitimate broke

Check	Result	Evidence
Test prompt "What is Northstar's hybrid work policy? Name the source document."	Answered with retrieval, 5 chunks	`evidence/task1/smoke_after_iam_*.json`
Runtime still writes its logs	50 log events written after the change	`evidence/task4/runtime_logs_after_hardening.json`
Knowledge base sync	Complete, 30 scanned, 0 failed	`evidence/task4/kb_sync_after_hardening.json`

7. What an attacker could do: original roles versus scoped roles

Scenario: an attacker controls what the agent does (a successful prompt injection), or can call `InvokeHarness` with the application's credentials.

Capability	Original roles	Scoped roles
Skip the guardrail with a per-request model override	Yes	No
Switch to another model (costlier, or with weaker safety behaviour)	Yes, any model in the account	No
Use the Browser tool to reach the internet	Permitted by IAM	Denied
Run code in the Code Interpreter	Permitted by IAM	Denied
Mount and write EFS or S3 Files file systems	Permitted by IAM	Denied
Read or plant long-term memory	Permitted by IAM	Denied
Retrieve from another knowledge base through the gateway	Agentic retrieval on any knowledge base	Denied
Probe other guardrails in the account	Permitted for the gateway role	Denied
Write into other agents' log groups	Permitted	Denied
Retrieve from the Northstar knowledge base through the tool	Yes	**Yes: this is the intended function**

The last row is the limit of IAM hardening. Least privilege removes everything the agent does not need; it cannot stop the agent from misusing what it does need. Disclosure of knowledge-base content through the legitimate Retrieve path is controlled by the guardrail and system prompt (Task 5), by monitoring (Task 6) and by reducing what the knowledge base contains (launch condition, Task 7).

8. Limitations and follow-up

1. **The guardrail condition pins guardrail versions.** The Deny names `guardrail/753a9dgwqe2f:2` and `guardrail/1oom74pzn70o:2`. Publishing a new guardrail version requires updating this policy in the same change, or the harness will be denied. This coupling is deliberate: a guardrail change then needs an IAM change, which is reviewable.

2. **Who may call `InvokeHarness` is outside these roles.** The three roles are service roles. The caller's permission to invoke the harness belongs to the application's identity. In production, `bedrock-agentcore:InvokeHarness` should be granted only to the application role, never to end users, and the application should not pass `model`, `systemPrompt` or `tools`.
3. **The system-prompt override is still honoured.** Probe O-2 was blocked because its request was off-scope and the guardrail caught it. A caller can still replace the system prompt while keeping the guardrail. The guardrail then becomes the only control, which is why point 2 matters.
4. **Rollback in the Cloud Lab.** The lab role may not call `iam:SetDefaultPolicyVersion`, so rollback is done by publishing the original document as a new version, with pruning to stay under IAM's five-version limit. The script handles this.
5. **The `bedrock:InferenceProfileArn` and `bedrock:GuardrailIdentifier` conditions are evaluated by Bedrock at request time.** The simulator confirms the policy logic; probes O-1, O-3 and O-4 confirm the live behaviour.
6. **One simulator gap.** The IAM policy simulator returned a deny for `logs:PutLogEvents` on a log-stream ARN even with the original policy in place, so it cannot be used for that action. Log writing is proven by the live log events in section 6.3 instead.